Technical & Operational Consent Controls Policy

Consent Management Platform (CMP) Governance, Automated Script Enforcement & Privacy Versioning

Document Ref:	POL-CMP-2026-v2	**Effective Date:**	July 31, 2026
Policy Owner:	Head of Frontend Eng & Data Privacy Officer	**Review Cycle:**	Bi-Annual / Post-Feature Release
Target Audience:	Engineering, DevOps, Product & Growth Marketing	**Compliance Basis:**	ePrivacy Directive & Art. 6/7/12 GDPR

1. Executive Summary & Purpose

Having legal privacy documentation drafted is only the first step toward compliance. Under the European Union General Data Protection Regulation (GDPR) and the ePrivacy Directive, Meridian Analytics is legally required to enforce active, technical consent controls across all web properties and SaaS application interfaces.

This document outlines the mandatory engineering standards, Consent Management Platform (CMP) architecture, zero-load script blocking protocols, and privacy policy versioning SLAs required to achieve full compliance with **gdprchecklist.io** standards.

> **Strict Regulatory Requirement:** Prior to firing any non-essential tracking scripts (e.g., Google Analytics, Hotjar, LinkedIn Insights, or ad pixels), users must give explicit, affirmative opt-in consent. Pre-ticked checkboxes, implied consent via scrolling, or pre-consent script execution are strictly prohibited and constitute non-compliance under EU law.

2. Scope & Applicable Platforms

This policy applies to all digital assets owned, operated, or maintained by Meridian Analytics, including:

- **Public Marketing Websites:** `https://meridiananalytics.io` and associated subdomains.
- **Customer Web Consoles & SaaS Dashboards:** `https://app.meridiananalytics.io`.
- **Documentation & Portal Sites:** `https://docs.meridiananalytics.io`.
- **Third-Party Landing Pages & Webforms:** Any micro-site or hosted form integrated with production databases.

3. Consent Management Platform (CMP) Architecture

Meridian Analytics mandates the deployment of an enterprise-grade CMP (e.g., OneTrust / Cookiebot / Klaro) configured to enforce deterministic script-blocking at the DOM level before user choices are registered.

3.1 Core CMP Technical Standards

1. **Default Blocked State (Zero-Load):** All analytical, functional, and marketing cookies/scripts are blocked by default. Only "Strictly Necessary" category scripts are permitted prior to user interaction.
2. **Explicit Affirmative Opt-In:** Consent must be expressed via a clear positive action (e.g., clicking "Accept All" or checking custom preference toggles and clicking "Save Preferences").
3. **No Pre-ticked Switches:** All category toggles in the preference center (except Necessary) must default to the "OFF" position.
4. **Equal Friction for Withdrawal:** Withdrawing consent must be as effortless as granting it. A persistent, floating privacy badge must remain pinned to the bottom-left corner of every page, launching the CMP preference drawer in one click.

5. **Consent Signal Transmission:** Integrated CMP must support Google Consent Mode v2 and pass standard signal parameters (`analytics_storage`, `ad_storage`, `ad_user_data`, `ad_personalization`) to downstream tags via Google Tag Manager (GTM).

4. Cookie Classification & Script Execution Taxonomy

Every script and local storage entry deployed across Meridian Analytics web properties must be categorized within the CMP registry before deployment to production.

Category	Provider / Tools	Purpose & Data Types	Lifespan	Default Status
Strictly Necessary	AWS ALB, Auth0, Application Session	Load balancing, session integrity, authentication, CSRF tokens.	Session	ALWAYS ACTIVE
Functional	Intercom, Zendesk Chat Widget	Remembers user preferences, localized settings, live support state.	12 Months	BLOCKED (OPT-IN)
Performance / Analytics	Google Analytics 4, Hotjar, PostHog	Aggregated traffic telemetry, page interaction heatmaps, performance metrics.	13 Months	BLOCKED (OPT-IN)
Marketing / Targeting	LinkedIn Insight Tag, Google Ads, Hubspot	Conversion tracking, campaign attribution, retargeting audience creation.	90 Days	BLOCKED (OPT-IN)

5. Technical Implementation Guidelines for Engineering

Frontend developers and web administrators must wrap all third-party tracking scripts with CMP blocking mechanisms or route them exclusively through GTM triggers tied to consent state events.

5.1 HTML Script Tag Wrapping (Direct CMP Blocking)

For direct script insertions, the standard `type="text/javascript"` attribute must be replaced with the CMP category controller tag:

```
<!-- Example Cookiebot Script Wrapping -->
<script type="text/plain" data-cookieconsent="preferences" src="https://widget.intercom.io/..."></
script>
<script type="text/plain" data-cookieconsent="statistics" src="https://www.googletagmanager.com/gtag/
js?id=G-XXXXX"></script>
<script type="text/plain" data-cookieconsent="marketing" src="https://snap.licdn.com/li.lms-analytics/
insight.min.js"></script>
```

5.2 Google Tag Manager (GTM) Trigger Configuration

- Configure GTM Consent Overview mode for all active tags.
- Set Additional Consent Checks for Google Analytics tags to require `analytics_storage = granted`.
- Set Marketing pixels to require `ad_storage = granted` and `ad_user_data = granted`.
- Block tag firing on `Page View`; fire only on custom events emitted by the CMP (e.g., `cookie_consent_update`).

6. Privacy Policy Versioning & Operational Change Protocol

When updates are made to the Public Privacy Policy, legal documentation alone is insufficient. The technical team must execute an operational change notification sequence.

> **Mandatory Notification SLA:** Any material change to processing activities, legal basis, subprocessor lists, or retention schedules requires proactive notification to active users at least **14 calendar days** prior to enforcement.

6.1 Step-by-Step Versioning Protocol

1. **Policy Code Tagging:** Each Privacy Policy release receives a semver tag (e.g., `v2.4.0`) and a published release date in the document header.
2. **Public Changelog Archive:** Maintain a public, machine-readable version history log at `https://meridiananalytics.io/privacy/history` detailing date, version, section modified, and nature of change.
3. **In-App Modal Prompt:** For major updates, deploy an automated, un-dismissible modal upon next admin log-in forcing review and explicit acknowledgement.
4. **System Audit Logging:** Capture timestamp, user ID, tenant account ID, and policy version acknowledged into the compliance database table (`compliance_consent_audits`).

7. Compliance Verification & Automated Auditing

To ensure continuous compliance, the Information Security team executes automated regression checks:

- **Weekly Automated Scans:** Automated headless browser tests (Playwright/Selenium) crawl all public pages in a fresh browser session, verifying zero network calls are dispatched to analytics/marketing domains prior to clicking "Accept".
- **Cookie Creep Audits:** Monthly scans register any unclassified cookies or local storage items dropped by third-party vendor scripts and automatically flag them for engineering review.
- **Consent Log Retention:** CMP consent logs (anonymized IP, consent string, timestamp, user choice) are stored securely in AWS S3 (eu-west-1) for 5 years to demonstrate compliance during DPA regulatory audits.

8. Governance & Roles Matrix

Role / Department	Responsibility
Head of Frontend Engineering	Ensures CMP integration across all repositories; validates script blocking in PRs.
Growth / Marketing Operations	Registers new marketing tags with Legal/CMP before deploying via GTM.
Data Protection Officer (DPO)	Reviews cookie classifications, approves LIA/DPIA updates, manages DPA inquiries.
SecOps & QA Team	Executes weekly automated script blocking scans and manages audit logs in AWS.